

AI Governance Strategy Assignment
Bevan Roy, CS-GY 9215 AI Governance, 5/3/2026

Utilizing the National Institute of Standards and Technology (NIST) AI RMF and CSF 2.0 as the main lens, I would not approve Bob's agent for production. The first use case, generating job descriptions, is a general task if HR retains review authority. The second use case, evaluating resumes against job descriptions, is materially different as it is part of an employment selection process and shapes who gets screened in or out. The Equal Employment Opportunity Commission says selection procedures must be job-related and consistent with business necessity and may not create unlawful disparate impact, while the European Commission explains that AI used to analyze or filter job applications and evaluate candidates is a high-risk employment use case under the EU AI Act (1, 2). The more serious design flaw is that Bob built the agent with his own credentials and then shared it with the team. The team can operate through Bob's access path and can see more systems and more personal information than they should. From a governance perspective, that is the opposite of least privilege and separation of duties. It also makes auditing more difficult as logs will tend to reflect Bob's authority or a shared privileged integration rather than the true human decision-maker (3). In course terms, this is exactly the kind of fact pattern the modules warned about. Module 3 argued for "risk by use case" and higher scrutiny for higher-risk uses whereas Module 2 flagged "excessive agency" and over-privileged models. Module 6 stated that what was not allowed before AI is not allowed with AI. All three principles are lacking here.

When regarding interconnected fields and systems, Bob's team has been given an AI capability without evidence of role-based training or clear instructions about what data may be used. In an HR setting, this is dangerous because user errors are of course not harmless (like uploading sensitive information). NIST's AI framework treats AI risk as socio-technical and holistic but not purely technical, and the EEOC has made clear that using software in hiring does not remove the employer's obligations under discrimination law (4). There is no evidence of a formal AI intake, classification, impact analysis, validation plan, or incident response playbook. That means the company has skipped the basic governance gates that should exist before an employment-related AI system is deployed. ISO's PIA guidance applies where personal information is collected, stored, used, or disclosed, and NIST's generative AI profile specifically calls for procurement diligence on data privacy, security, intellectual property, third-party risks, and ongoing monitoring. Since the tool is supposed to be an agentic system and possibly interact with downstream applications. That creates a modern app-sec problem. The OWASP Foundation GenAI project identifies prompt injection as a vulnerability in which user prompts model behavior in unintended ways, including disclosure of sensitive information, unauthorized access to functions, arbitrary command execution in connected systems, and manipulation of critical decision-making. Its "excessive agency" category specifically warns against extensions with unnecessary functionality, excessive permissions, and excessive autonomy (5).

There is also no sign of a functional operating model involving HR, Security, Privacy, and other teams involved. That matters because hiring AI is not just an HR productivity tool. It

involves interconnected risk, employment law, privacy rights, model governance, and security architecture at the same time. NIST's AI RMF puts executive leadership responsibility, lifecycle oversight, and workforce processes directly inside the "Govern" function, and ISO 42001 is built around a management-system approach rather than ad hoc tool usage (9).

In terms of use case, I would separate the two stated purposes immediately. Job-description generation can be treated as a supervised drafting aid, because the final result can be reviewed against company templates, legal work and approved competencies before publication. Resume evaluation is different because it informs employment decisions. The EEOC has shown longstanding guidance on employment tests and selection procedures that focus on disparate impact and business necessity, while the EU AI Act classifies employment uses such as filtering job applications and evaluating candidates as high-risk (1, 2). In governance terms, the screening function deserves the higher-risk classification, not the drafting function. Data privacy is a severe issue. The stated purpose does not require Bob's team to access salary, home address, or personal contact information for existing employees, yet the current design exposes the agent to that broader HR context. That is a failure of data minimization and purpose limitation. For a resume-evaluation workflow, the system should operate on a sharply defined data set that includes the job requisition, the approved requirements, and the candidate materials needed for lawful screening. Privacy governance should include a PIA, minimization rules, tokenization of unnecessary identifiers, retention limits, and restrictions on whether prompts or data may be reused by the provider (6). The model type matters because LLMs can hallucinate and behave unpredictably when tied to downstream tools. NIST's generative AI profile highlights prompt injection, data privacy, information security, third-party integration risk, and the need to detect PII or sensitive data in outputs. That means the company should not treat the model as a neutral "helper" and should not be used for unnecessary actions (7).

One major missing principle as discussed prior is least privilege. Bob's broader HR access should never have become the team's effective access path. Next is separation of duties, the same privileged identity should not be used both to build and to operate a system that influences hiring outcomes. Alongside this is data access limiting on the model used. The system should only see the minimum data required for the approved purpose. Furthermore, human oversight is another consideration as no candidate should be rejected solely because a model made an unsupported recommendation. The company also needs technical, procedural, and contractual controls, not just a policy. Finally, monitorability and recoverability are missing. The company needs logs, anomaly detection, incident criteria, and a kill switch before the system goes live. Module 2 also supports this with its warnings about over-privileged systems and "excessive agency." Module 4 on Risk Management and AI Code Generation stressed that use cases get the highest weight, that high-risk systems need human oversight and a kill switch, and that people, process, and organizational controls matter as much as technical ones. Module 6 connected privacy and bias directly to AI operations. The scenario again comes short for these principles (8).

One control that can be implemented is diverting workflows. One would be the AI assistant for job-description drafting and another, much more controlled system for resume evaluation. The drafting workflow may use a standard approved prompt library and approved templates. The screening workflow should be treated as high-risk and should not use Bob's personal access information. Secondly, we must look to replace shared access models with individual identity, role-based access control, and read-only permissions wherever possible. The agent should authenticate to downstream systems with the minimum scopes needed for the approved task, and high-impact actions should require human confirmation. Shared credentials should be prohibited. Also necessary is to constrain the data boundary. The system should only ingest the job requisition, approved evaluation criteria, and submitted materials required. It should be technically blocked from sensitive information. Contracts and settings should specify retention, logging, and deletion requirements. A privacy impact assessment should also be mandatory before deployment and whenever the workflow changes materially (3, 6).

Validation of the tool should also be done and before launch, HR and Legal should document why each screening criterion is job-related and tied to business necessity. The system should undergo adverse testing, accuracy and consistency checks, sampling against human benchmarks, and documentation strong enough for verification and audit. After deployment, the same testing should continue on a recurring basis, because drift and process changes can reintroduce bias even if the first version looked acceptable. Furthermore, I would require an AI intake form accompanied by a vendor due diligence, change control, and periodic review by a cross-functional governance body. In practice, I would structure the program around ISO's AI management system which leverages policy, lifecycle controls, human oversight, monitoring, improvement, and evidence suitable for audit (1, 6).

Utilizing the CSF 2.0 structure/cyber-life cycle Protect should include user identity, least privilege, approved prompts, data minimization, segregation of HR data domains, vendor restrictions, and training for recruiters and hiring managers. Detect means continuous monitoring of both cybersecurity and model behavior. Here that should include logging of prompts and calls, monitoring for unusual patterns, privileged reviews, detection of data exposure in outputs, prompt-injection indicators, model-performance drift, and recurring bias. I would put Respond/Defend as both a response and containment. When suspicious activity appears, the company should revoke tokens, disable the agent, preserve logs and notify cases back to a human-only process. The screening workflow should have a kill switch and a preapproved manual fallback. Recover means restoring only a validated version of the workflow, verifying the integrity of restored assets, and updating controls after lessons learned. It should mean revalidating access scopes, re-running fairness and security tests, confirming that sensitive data was not exposed, and documenting the root cause before resuming use (3).

References

- 1) *Employment Tests and Selection Procedures*, EEOC, December 1, 2007.
<https://www.eeoc.gov/laws/guidance/employment-tests-and-selection-procedures>
- 2) *AI Act*, European Commission, February 2, 2025.
<https://digital-strategy.ec.europa.eu/en/policies/regulatory-framework-ai>
- 3) *The NIST Cybersecurity Framework 2.0*, NIST, February 26, 2024.
<https://nvlpubs.nist.gov/nistpubs/CSWP/NIST.CSWP.29.pdf>
- 4) *Artificial Intelligence Risk Management Framework*, NIST, January, 2023.
<https://nvlpubs.nist.gov/nistpubs/ai/nist.ai.100-1.pdf>
- 5) *Prompt Injection*, OWASP GenAI Security Project, 2025.
<https://genai.owasp.org/llmrisk/llm01-prompt-injection/>
- 6) *ISO 29134:2023 Information technology — Security techniques — Guidelines for privacy impact assessment*, ISO, 2023. <https://www.iso.org/standard/86012.html>
- 7) *Artificial Intelligence Risk Management Framework: Generative Artificial Intelligence Profile*, NIST, July 2024. <https://nvlpubs.nist.gov/nistpubs/ai/NIST.AI.600-1.pdf>
- 8) *Security and Privacy Controls for Information Systems and Organizations*, NIST, September 2020.
<https://nvlpubs.nist.gov/nistpubs/SpecialPublications/NIST.SP.800-53r5.pdf>
- 9) *ISO 42001:2023 Information Technology — Artificial Intelligence — Management System*, ISO, 2023. <https://www.iso.org/standard/42001>